



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-50751 Check Point Security Gateway Improper Authentication Vulnerability

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-08
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-50751 Check Point Security Gateway Improper Authentication Vulnerability - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-08 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-50751 Check Point Security Gateway Improper Authentication Vulnerability

1. Executive Summary

CVE-2026-50751 is a critical, actively exploited authentication-bypass vulnerability affecting Check Point Remote Access VPN, Mobile Access, and Spark Firewall deployments that still permit the deprecated IKEv1 key-exchange path. Check Point, the CVE Program, NVD, and CISA all align on the core risk: an unauthenticated remote attacker can bypass user authentication and establish a remote access VPN connection without a valid password by abusing a logic-flow weakness in certificate validation.

The exposure is configuration dependent, which matters for prioritization. Check Point's support advisory states exploitation requires all of the following: Remote Access or Mobile Access enabled, IKEv1 enabled for remote access, acceptance of legacy Remote Access clients, and no mandatory machine certificate requirement. That means not every gateway branch listed by the vendor is automatically exploitable, but internet-facing VPN edge infrastructure matching those conditions should be treated as emergency-risk until positively verified and remediated.

Operational urgency is high. CISA added the flaw to the Known Exploited Vulnerabilities catalog on 2026-06-08 with a 2026-06-11 due date for federal agencies, while Check Point reported active exploitation observed from at least early May and tied one post-compromise case with medium confidence to a Qilin ransomware affiliate. Rapid7 independently reported observed exploitation and reinforced the need for emergency patching, retrospective hunting, and validation of IKEv1-related exposure.

Confirmed facts:

- CVE ID: CVE-2026-50751
- Vendor: Check Point
- Product families: Quantum Security Gateway, Remote Access VPN / Mobile Access, Spark Firewall
- Vulnerability class: Improper authentication
- Primary impact: Unauthorized remote-access VPN session establishment
- CWE: CWE-287 Improper Authentication
- CVSS v3.1: 9.3 Critical
- CVSS v3.1 vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N
- CVSS v4.0: 9.3 Critical
- CVSS v4.0 vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:L/SC:N/SI:N/SA:N
- KEV date added: 2026-06-08
- KEV due date for FCEB agencies: 2026-06-11
- Exploitation status: Confirmed in the wild
- Highest-risk preconditions: IKEv1 enabled, legacy Remote Access clients allowed, machine certificate not required

Analyst assessment:

- Treat externally reachable Check Point remote-access infrastructure as a patch-and-hunt priority, not a routine maintenance item.
- Assume opportunistic targeting will increase quickly because the issue is now in KEV and vendor indicators plus mitigation paths are public.
- Prioritize both emergency remediation and retrospective review of VPN/IKE logs; a successful bypass can yield trusted-looking remote access instead of a noisy crash or brute-force pattern.

2. Vulnerability Metadata

Field	Value
CNA / vendor	Check Point
CVE Program public date	2026-06-08

NVD published date	2026-06-08
NVD status at review time	Awaiting Analysis
CISA KEV date added	2026-06-08
CISA KEV due date	2026-06-11
Product family	Quantum Security Gateway / Spark Firewall remote access stack
Exposed components	Remote Access VPN and Mobile Access using deprecated IKEv1
Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Changed (CVSS v3.1)
Confidentiality / Integrity / Availability impact	High / Low / None (CVSS v3.1)
Vendor weakness mapping	CWE-287 Improper Authentication
Quantum Security Gateway	R82.10 with Jumbo Hotfix Take 19 or below
Quantum Security Gateway	R82 with Jumbo Hotfix Take 103 or below
Quantum Security Gateway	R81.20 with Jumbo Hotfix Take 141 or below
Quantum Security Gateway	R81.10, R81, and R80.40 (all EOS branches called out as affected)
Spark Firewall	R80.20.X, R81.10.X, and R82.00.X

Key metadata: Affected-version guidance reflected in Check Point support, the CVE Program, and vendor blog content:

Configuration preconditions required for exploitability:

Operational implications:

- VPN Remote Access or Mobile Access enabled
- IKEv1 enabled for remote access
- Legacy Remote Access clients allowed
- Machine certificate authentication not required
- Exposure depends on both software branch and remote-access configuration state; inventory and settings review matter as much as patch level.
- The vulnerable surface sits on the organization's remote-access edge, so successful exploitation can provide attacker network foothold without valid user credentials.
- Older end-of-support branches remain in the affected set, increasing residual risk for environments that delayed lifecycle upgrades.

3. Source Review & Confidence

Primary-source basis: Secondary-source basis:

Source	Contribution	Confidence
Vendor support advisory	Check Point describes CVE-2026-50751 as	High-confidence primary source for

	a user-authentication bypass in VPN Remote Access and Mobile Access tied to depr	canonical remediation guidance, vulnerable-configuration scoping,
Vendor security advisory / research blog	Check Point reported active exploitation of CVE-2026-50751, listed affected products and branches, published IOC IPs and	High-confidence primary source for exploitation status, affected branches, and vendor-published IOC
Government KEV feed	CISA lists CVE-2026-50751 as a known exploited vulnerability added on 2026-06-08 with a due date of 2026-06-11. The feed	High-confidence primary source for KEV inclusion, due date, and federal remediation urgency.
Government vulnerability database API	NVD provides the normalized CVE description, CVSS v3.1 9.3 Critical scoring, and CWE-287 weakness mapping while the reco	High-confidence primary source for normalized scoring and weakness metadata.
CVE Program API	The CVE Program record confirms affected Quantum Security Gateway and Spark Firewall branches, restates the unauthentic	High-confidence primary source for canonical affected-product scoping and CNA metrics.
Secondary reporting / incident-response field analysis	Rapid7 independently described active exploitation, reiterated the exploitability preconditions (IKEv1, legacy clients,	Secondary source used to corroborate field exploitation and operational defender guidance rather tha

Confidence assessment:

4. Vulnerability Details

Check Point describes CVE-2026-50751 as a user-authentication bypass in VPN Remote Access and Mobile Access tied to deprecated IKEv1 key exchange. The flaw stems from a logic-flow weakness in how Remote Access and Mobile Access certificate validation is handled. If the vulnerable conditions are present, an unauthenticated attacker can establish a remote access VPN connection without supplying a valid user password.

The most important nuance is that this is not a blanket flaw across every Check Point gateway deployment. The vendor advisory explicitly requires four conditions: remote-access functionality enabled, IKEv1 enabled, support for legacy clients enabled, and machine-certificate authentication not required. That narrows the immediately exploitable surface, but it also means many organizations may underestimate risk if they focus only on version numbers and do not validate remote-access policy settings.

From a defender perspective, the issue is high impact because the outcome is not merely a malformed request or denial of service; it is a potentially successful remote-access session on the network edge. Once the VPN tunnel is established, follow-on attacker behavior can resemble legitimate remote-access activity and blend into account- and session-centric telemetry unless teams specifically inspect IKE/Quick Mode and certificate-authentication events.

5. Attack Scenarios

Scenario 1: Opportunistic exploitation of exposed legacy-compatible VPN gateways

- An attacker identifies an internet-facing Check Point gateway exposing Remote Access or Mobile Access.
- The target still allows IKEv1 and legacy Remote Access clients and does not require a machine certificate.
- The attacker abuses the certificate-validation logic weakness to bypass user authentication.
- A VPN session is established, giving the attacker initial access from the remote-access edge.

Scenario 2: Targeted access against organizations with older or neglected gateway branches

- A threat actor inventories enterprises still operating affected R81.x, R82.x, or Spark branches, especially end-of-support versions.
- Remote-access policy choices are inferred or tested through exposed VPN behavior and subsequent IKE activity.

- Successful bypass produces a foothold suitable for internal reconnaissance, credential abuse, or ransomware staging.

Scenario 3: Post-disclosure scaling after KEV inclusion

- Public advisory coverage and KEV listing increase attacker awareness and target prioritization.
- Organizations that delay patching or rely only on perimeter ACL assumptions remain exposed.
- Even failed attempts may still leave useful traces in SmartConsole logs, especially around Key Install and Quick Mode IKE events from known attacker infrastructure.

6. Threat Landscape & Exploitation Status

CISA added CVE-2026-50751 to the KEV catalog on 2026-06-08, which is the strongest public signal that exploitation has been confirmed in the wild and that remediation should be treated as urgent. The KEV feed describes the issue as an improper-authentication flaw in IKEv1 key exchange that can let an unauthenticated attacker establish a remote-access VPN connection.

Check Point states it identified active exploitation, with indications that exploitation attempts increased in early June. The vendor's attack timeline references suspicious activity that triggered investigation on 2026-06-04 and a search window beginning 2026-05-07, indicating the exploitation window predates public disclosure. Check Point further assessed with medium confidence that at least one observed post-compromise case was associated with a Qilin ransomware affiliate.

Rapid7 independently described the issue as an exploited Check Point VPN zero-day and reiterated that the highest-risk configuration combines IKEv1, support for legacy clients, and absence of mandatory machine certificates. Rapid7 also recommended compromise assessment after patching, which is sound operational guidance because patching alone does not answer whether a vulnerable gateway was previously abused.

CISA's KEV feed currently lists `knownRansomwareCampaignUse` as `Unknown`. That should be interpreted as a catalog-data point rather than a contradiction of Check Point's assessment. The public reporting supports the broader conclusion that financially motivated actor activity is already present and that defenders should scope for post-authentication abuse even if they do not adopt a named-actor attribution in executive messaging.

7. Affected Products and Exposure

Confirmed product impact:

- Quantum Security Gateway branches called out in Check Point support and CVE Program data
- Spark Firewall branches called out in Check Point support and CVE Program data
- Remote Access VPN and Mobile Access deployments using deprecated IKEv1 and legacy-client acceptance

Highest-priority exposure classes:

- Internet-facing Check Point VPN gateways with legacy client compatibility enabled
- Organizations that still support IKEv1 for business or compatibility reasons
- Environments running end-of-support R80.40, R81, or R81.10 branches
- Remote-access gateways used by administrators, third parties, or broad workforce populations

Immediate scoping questions:

- Which Check Point gateways expose Remote Access or Mobile Access services to the internet or partner networks?
- Where is IKEv1 still enabled for remote access?
- Which gateways still allow older / legacy Remote Access clients?
- Where is machine-certificate authentication optional or disabled?
- Which affected branches remain below the Check Point hotfix levels or on EOS trains?
- Which systems retain SmartConsole logs covering at least 2026-05-07 onward?

Useful local pivots:

- Check Point gateway inventory and software-branch records
- SmartConsole policy and object configuration for VPN Clients / Authentication
- Remote-access and Mobile Access settings showing IKE version and client-acceptance choices
- SmartConsole logs, especially Key Install / Quick Mode IKE activity
- SIEM, EDR, and network-flow telemetry keyed to VPN-assigned addresses or anomalous remote-access sessions

8. Mitigation and Workarounds

Immediate actions:

- Apply the Check Point hotfixes for every affected gateway branch on an emergency basis.
- Identify every gateway where IKEv1 remains enabled for remote access and determine whether business requirements still justify it.
- Remove support for legacy Remote Access clients where possible.
- Configure Remote Access VPN authentication to IKEv2 only where operationally safe.
- Require machine-certificate authentication for remote-access connections where the deployment supports it.
- Preserve and review logs before making large configuration changes if compromise is suspected.

Check Point mitigation options documented in sk185033:

- Option 1: Clear the “Allow older clients to connect to this gateway” setting in SmartConsole under VPN client authentication and define stronger allowed authentication methods.
- Option 2: Configure global Remote Access VPN authentication properties to IKEv2 only, reducing exposure to the deprecated IKEv1 path.
- Option 3: Set machine certificate authentication as mandatory for applicable connections.
- Hotfix path: Upgrade to fixed takes above the vulnerable levels documented in the advisory for the relevant branch.

Workaround note:

- The authoritative remediation path is Check Point hotfix installation plus elimination of unsafe remote-access settings.
- The configuration mitigations materially reduce exposure, but they should be treated as emergency controls or hardening steps rather than substitutes for supported updates.
- Branches already at end of support should be treated as lifecycle-risk even if temporary mitigations are applied.

9. Detection Engineering

Detection priorities: Recommended telemetry: Practical analytic themes: Illustrative public indicators: Because infrastructure can rotate quickly, defenders should not rely solely on the published IOC list. The most durable detections are IKEv1 / legacy-client exposure validation, Key Install / Quick Mode review, and anomalous remote-access sessions that do not fit known user-device patterns.

Signal	Telemetry Source	Analytic Goal
SmartConsole events showing suspicious certificate-authentication or VPN session establishment tied to the published attacker IPs	Network, auth, proxy, or service-access logs	Identify externally reachable or suspiciously accessed systems
`Key Install` events involving known malicious source or destination infrastructure	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
`Key Install` events containing `Quick`, since Check Point notes a successful exploit requires a Quick Mode key install	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Remote-access activity from systems or geographies inconsistent with expected workforce behavior	Network, auth, proxy, or service-access logs	Identify externally reachable or suspiciously accessed systems
Post-VPN internal activity that follows unusual IKE / remote-access log patterns	Network, auth, proxy, or service-access logs	Identify externally reachable or suspiciously accessed systems

9.1 Detection Query

```
// Check Point VPN exposure and legacy-IKE hunting pivots
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (500, 4500, 443)
| project Timestamp, DeviceName, InitiatingProcessFileName, LocalIP, RemoteIP, RemotePort, RemoteUrl
| order by Timestamp desc
```

9.2 Exposure / Triage Query

```
// Pivot on suspicious VPN or authentication telemetry after external access
DeviceLogonEvents
| where Timestamp > ago(30d)
| where LogonType has_any ("RemoteInteractive", "Network")
| summarize LogonCount=count() by DeviceName, AccountName, RemoteIP, bin(Timestamp, 1h)
| where LogonCount > 5
| order by LogonCount desc
```

10. Threat Hunting

Hunt objectives:

- Determine which internet-facing or partner-facing gateways met all exploitability preconditions during the exposure window.
- Identify suspicious Key Install / Quick Mode activity involving the vendor-published infrastructure.
- Correlate suspicious VPN establishment with downstream internal access, credential use, or ransomware precursor behavior.
- Distinguish noisy scanning from sessions that appear to have resulted in successful remote access.

Suggested hunt questions:

- Which gateways had Remote Access or Mobile Access enabled with IKEv1 still allowed?
- Which of those gateways also permitted older clients and did not require machine certificates?
- Do SmartConsole logs from 2026-05-07 through 2026-06-05 show infrastructure matches to the public IOC list?
- Which Key Install events contain `Quick` and align with suspicious remote endpoints?
- Did any suspicious remote-access session precede internal reconnaissance, privileged logon activity, file transfer, or encryption staging?

Useful local pivots:

- Historical SmartConsole logs, especially `action:"Key Install"` activity
- VPN-assigned address histories and firewall logs for subsequent internal reachability
- EDR timelines for assets accessed after suspicious VPN establishment
- Identity logs for unusual post-authentication activity after remote-access events
- Configuration snapshots showing when IKEv1, legacy-client support, or machine-certificate requirements changed

10.1 Hunt Query

```
// Pivot on suspicious VPN or authentication telemetry after external access
DeviceLogonEvents
| where Timestamp > ago(30d)
| where LogonType has_any ("RemoteInteractive", "Network")
| summarize LogonCount=count() by DeviceName, AccountName, RemoteIP, bin(Timestamp, 1h)
| where LogonCount > 5
| order by LogonCount desc
```

11. MITRE ATT&CK Mapping

Mapped ATT&CK techniques:

- T1190 - Exploit Public-Facing Application

- Rationale: The vulnerable surface is an externally reachable VPN / remote-access edge service that can be exploited over the network.
- T1133 - External Remote Services
- Rationale: Successful exploitation yields unauthorized access through the organization's VPN remote-access service.
- T1078 - Valid Accounts
- Rationale: Although the initial condition is an authentication bypass, successful access can present downstream as a legitimate authenticated remote-access session and complicate account-centric monitoring.

Interpretation:

- T1190 captures exploitation of the exposed edge service.
- T1133 captures the attacker objective and practical result: external remote-access foothold.
- T1078 reflects the defensive challenge that a bypassed-but-established VPN session may blend into normal remote-access telemetry.

12. Validation / Lab Testing

Safe validation steps:

- Inventory every Check Point gateway in scope and confirm branch / take levels.
- Review Remote Access and Mobile Access settings for IKEv1 enablement, legacy-client support, and machine-certificate requirements.
- Confirm hotfix installation against the vendor branch guidance rather than only general version names.
- Review retained SmartConsole logs for infrastructure hits and Key Install / Quick Mode activity.
- Use only vendor-supported configuration review and patching workflows; do not attempt live exploit validation against production gateways.

Recommended validation checklist:

1. Build a complete list of affected Quantum Security Gateway and Spark Firewall systems.
2. Verify whether each system exposes Remote Access or Mobile Access externally.
3. Confirm whether IKEv1 is enabled for remote access on each system.
4. Confirm whether older legacy clients are still allowed.
5. Validate whether machine certificate authentication is mandatory.
6. Apply the required Check Point hotfixes or emergency mitigations.
7. Hunt historical logs back to at least 2026-05-07 and escalate any suspicious Quick Mode / Key Install findings for full compromise assessment.

13. Recommended Actions Summary

Critical - Network / Security Infrastructure Owners - 24 hours Critical - Detection / SOC - 24 hours High - Identity / IT Operations - 72 hours

Priority	Owner	Action
Critical	Platform / Application Owners	Patch every affected Check Point gateway branch to the vendor hotfix level or later.
High	Security / Platform Owners	Disable legacy-client support and move Remote Access authentication to IKEv2-only where operationally possible.
High	Security / Platform Owners	Require machine certificates for remote-access connections where supported.
Critical	Platform / Application Owners	Prioritize replacement or accelerated

		upgrade for end-of-support branches still providing remote access.
High	SOC / Detection Engineering	Hunt SmartConsole logs from at least 2026-05-07 onward for the published IP infrastructure and for `action:"Key Install"` events containing `Quick`.
High	Security / Platform Owners	Investigate any suspicious VPN establishment for downstream internal activity, privileged access, or ransomware precursor behavior.

14. References

See `references.md` for the curated source list and `sources.md` for analyst confidence notes.